

SecCheck

관리자 가이드

SecCheck 를 설치하고 운영하는 사람을 위해

버전 v1.0.144

작성일 2026-09-11

문서 관리자 가이드

SecCheck 관리자 가이드

이 문서는 SecCheck 를 띄워 놓고 지키는 사람을 위한 안내입니다. 설치, 설정, 계정과 권한, 백업·복구·업그레이드, 장애 대응, 보안 기본값을 다룹니다. 화면을 쓰는 방법은 [사용자 가이드](#)에 있으며 여기서는 반복하지 않습니다. API 와 MCP 연계는 [api-guide.md](#), Prometheus 지표 전체 목록은 [operations.md](#)를 보십시오.

화면 캡처는 모두 데모 데이터(데모 회사 , hong@example.com)를 채운 실제 화면입니다.

1. 구성 요소

구성 요소	무엇	주요받는 것
seccheck 컨테이너	Go 단일 바이너리. HTTP 서버, 정적 UI, Rule Engine, 증적 암호화, 감사로그 해시 체인, 알림·증적 검사 백그라운드 워커, 매시간 정기 점검	:8080 으로 HTTP 수신. PostgreSQL 에 연결. /app/data 에 암호화된 증적 저장
PostgreSQL 17	심의·템플릿·감사로그·설정·작업 큐·서버 로그의 유일한 저장소	POSTGRES_DSN 으로 연결. 마이그레이션은 기동 시 자동 적용
증적 볼륨 (/app/data)	AES-256-GCM 으로 암호화된 증적 파일. UUID 파일명	데이터베이스와 같은 시점으로 백업해야 함
Reverse Proxy (권장)	TLS 종단, 접근 허용 목록	X-Forwarded-For 를 trusted_proxies 에 등록해야 접속 IP 가 올바르게 기록됨
Keycloak / OIDC IdP (선택)	사내 SSO	Authorization Code + PKCE. Callback <code>https://<host>/api/v1/auth/oidc/callback</code>
SMTP 서버 (선택)	이메일 알림	서비스 설정 > 알림. 없으면 인앱 알림만 남음
ClamAV clamd (선택)	증적 악성코드 검사	서비스 설정 > 파일 보안. 없으면 검사를 건너뛴(검사 안 함)

Redis, 외부 CDN, 인터넷 연결은 필요하지 않습니다. UI, 한글 PDF 글꼴, 기본 체크리스트 workbook, 마이그레이션이 모두 이미지에 들어 있습니다.

2. 설치

릴리즈 자산 하나(seccheck-v1.0.144.tar.gz)로 처음부터 끝까지 올리는 순서입니다. 아래 명령은 그대로 붙여 넣을 수 있으며, 값은 예시이므로 실제 값으로 바꾸십시오.

2-1. 요구 사항

항목	값
포트	컨테이너 8080/tcp 하나. 외부에는 Reverse Proxy 의 443 만 엽니다
볼륨	seccheck-data → /app/data (증적). 컨테이너 루트 파일시스템은 읽기 전용, /tmp 는 128 MB tmpfs
데이터베이스	PostgreSQL 16 이상(릴리즈 검증은 16·17). 전용 데이터베이스와 전용 계정. pg_trgm 확장을 만들 수 있으면 검색이 인덱스를 탑니다
자원	소규모 조직 기준 CPU 1, 메모리 512 MB 로 시작. DB 연결 풀은 CPU 수에 맞추되 최소 10
시간대	컨테이너는 UTC 로 동작하고 표시 시간대는 서비스 설정에서 정합니다(기본 Asia/Seoul)

2-2. 이미지 적재

```
sha256sum seccheck-v1.0.144.tar.gz # 릴리즈 노트에 적힌 sha256 과 대조
docker load -i seccheck-v1.0.144.tar.gz
docker image inspect seccheck:v1.0.144 --format '{{index .Config.Labels "org.opencontainers.image.version"}}
```

2-3. 데이터베이스 준비

```
CREATE ROLE seccheck LOGIN PASSWORD '<db-password>';
CREATE DATABASE seccheck OWNER seccheck;
\c seccheck
CREATE EXTENSION IF NOT EXISTS pg_trgm; -- 선택. 없으면 경고만 남기고 순차 스캔으로 동작
```

2-4. compose 로 기동

릴리즈 자산은 이미지 tar 하나뿐이므로 폐쇄망에서는 저장소의 `compose.yaml` 을 받을 수 없습니다. 아래가 그 파일의 전문입니다 — 이 가이드는 저장소의 `compose.yaml` 과 한 글자도 다르지 않게 유지됩니다(테스트가 대조합니다). 기동할 디렉터리에 `compose.yaml` 이라는 이름으로 그대로 저장하십시오. `image:` 의 태그는 2-2 절에서 적재한 태그와 같아야 합니다.

```

services:
  seccheck:
    image: seccheck:v1.0.144
    container_name: seccheck
    restart: unless-stopped
    stop_grace_period: 25s
    pids_limit: 256
    ports:
      - "8080:8080"
    environment:
      POSTGRES_DSN: ${POSTGRES_DSN:?required}
      BOOTSTRAP_ADMIN: ${BOOTSTRAP_ADMIN:?required}
      BOOTSTRAP_ADMIN_PASSWORD: ${BOOTSTRAP_ADMIN_PASSWORD:?required}
      ENCRYPTION_KEY: ${ENCRYPTION_KEY:?required}
    volumes:
      - seccheck-data:/app/data
    read_only: true
    tmpfs:
      - /tmp:size=128m,noexec,nosuid,nodev
    security_opt:
      - no-new-privileges:true
    cap_drop:
      - ALL
    healthcheck:
      test: ["CMD", "/app/seccheck", "healthcheck"]
      interval: 30s
      timeout: 5s
      retries: 3
      start_period: 20s

volumes:
  seccheck-data:

```

`ports` 의 앞 숫자(호스트 포트)와 Reverse Proxy 뒤에서만 받을 때의 `127.0.0.1:8080:8080` 같은 바인딩 외에는 바꾸지 않는 것을 권장합니다. `read_only` · `cap_drop` · `no-new-privileges` 는 7 절의 보안 기본값이고, `?:required` 는 네 변수 중 하나라도 비어 있으면 `compose` 가 기동 전에 멈추게 합니다.

네 개의 환경 변수는 같은 디렉터리의 `.env` 파일에 두고, 그 파일은 저장소에 넣지 마십시오.

```
cat > .env <<'EOF'
POSTGRES_DSN=postgres://seccheck:<db-password>@db.internal:5432/seccheck?sslmode=verify-full
BOOTSTRAP_ADMIN=admin
BOOTSTRAP_ADMIN_PASSWORD=<12자 이상, 설치 직후 바꿀 값>
ENCRYPTION_KEY=<32바이트 원문 또는 base64 32바이트>
EOF
chmod 600 .env
openssl rand -base64 32      # ENCRYPTION_KEY 만들기
docker compose up -d
docker compose logs -f seccheck  # "SecCheck started" 가 보이면 기동 완료
curl -fsS http://127.0.0.1:8080/ready
```

ENCRYPTION_KEY 는 증거와 비밀 설정을 감싸는 마스터 키입니다. **데이터베이스·볼륨 백업과 따로 보관하고 이중 통제하십시오. 잃어버리면 증거를 되돌릴 방법이 없습니다.**

2-5. 최초 관리자 계정

BOOTSTRAP_ADMIN 계정은 **첫 기동에만** 만들어지며 그때 7개 역할 중 6개(시스템 관리자·체크리스트 관리자·보안 담당자·승인자·심의 요청자·감사자)를 받습니다. 이후 재기동은 SYSTEM_ADMIN 만 보장하고, 이미 있는 계정의 비밀번호는 덮어쓰지 않습니다.

1. `https://<host>/login` 에서 부트스트랩 계정으로 로그인합니다.
2. 개인 프로필에서 비밀번호를 바꿉니다.
3. 사용자 · 역할 에서 실제 운영자 계정을 만들고 역할을 부여합니다(4 절).
4. SSO 를 쓰는 조직은 서비스 설정 > Keycloak OIDC 를 구성한 뒤(3-3 절), SSO 관리자가 로그인되는 것을 확인하고 부트스트랩 계정을 비활성화합니다.
5. 시스템 정보 에서 버전·스키마·한글 글꼴·저장 공간을 확인합니다.

부트스트랩 계정을 잃어버렸을 때는 컨테이너 안에서 복구합니다.

```
docker compose exec seccheck /app/seccheck admin-recover --username admin --password '<새 비밀번호>' --unloc
```

2-6. 배포 자체 점검

```
SECHECK_SELFTEST_PASSWORD='<관리자 비밀번호>' docker compose exec seccheck \
/app/seccheck selftest --base-url http://127.0.0.1:8080 --username admin
```

준비 상태, 로그인, OpenAPI, 게시 템플릿, 감사 체인을 확인합니다. `--full` 을 붙이면 심의 생성과 Excel·PDF·ZIP 내 보내기, 취소까지 수행하므로 **검증 환경에서만** 쓰십시오. 한글 글꼴 누락 같은 이미지 결함은 이 단계에서만 드러납니다. 실패하면 종료 코드 1 입니다.

3. 설정

3-1. 환경 변수

런타임이 읽는 환경 변수는 아래가 전부입니다(`internal/app/config.go`). 그 외 정책은 모두 서비스 설정 화면에서 바꾸고 저장 즉시 적용됩니다.

이름	기본 값	필수	설명
POSTGRES_DSN	(없음)	필수	PostgreSQL 연결 문자열. <code>sslmode=verify-full</code> 권장. <code>pool_max_conns</code> · <code>pool_min_conns</code> 를 주면 그대로 씁니다. 예: <code>postgres://seccheck:<db-password>@db.internal:5432/seccheck?sslmode=verify-full</code>
BOOTSTRAP_ADMIN	(없음)	필수	최초 기동 때 만들 로컬 관리자 아이디
BOOTSTRAP_ADMIN_PASSWORD	(없음)	필수	그 계정의 비밀번호. 12자 미만이면 기동을 거부합니다. 이미 있는 계정에는 적용되지 않습니다
ENCRYPTION_KEY	(없음)	필수	32바이트 원문 또는 base64 로 인코딩한 32바이트. 저장된 데이터 키와 맞지 않으면 기동을 거부합니다(<code>ENCRYPTION_KEY does not match this database</code>)
SECHECK_SELFTEST_PASSWORD	(없음)	선택	<code>seccheck selftest</code> 명령이 <code>--password</code> 대신 읽는 값. 서버 런타임은 읽지 않습니다

수신 주소(`:8080`), 증적 경로(`/app/data`), 정적 UI 경로는 바이너리에 고정되어 있습니다. 포트를 바꾸려면 `compose` 의 포트 매핑을 바꾸십시오.

3-2. 서비스 설정 화면

서비스 설정 은 여섯 탭입니다. 아래 키 이름은 `PUT /api/v1/admin/settings/{key}` 로도 같은 값을 다룰 때 쓰는 이름입니다.

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

서비스명

SecCheck

표시 시간대

Asia/Seoul

세션 시간(분)

480

보존 기간(일)

1825

서비스 주소

https://seccheck.company.internal

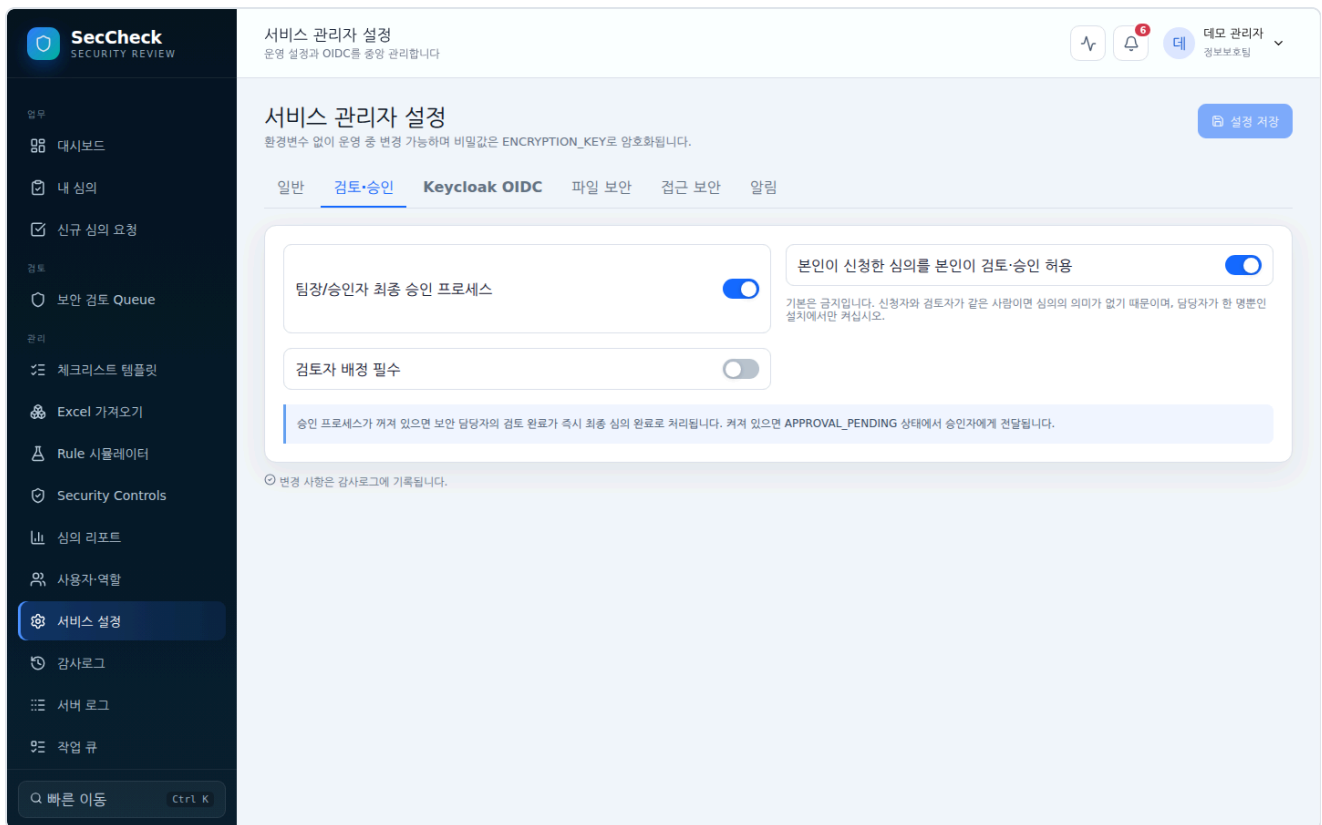
알림 메일의 바보가기 링크에 사용합니다. 비워 두면 링크를 넣지 않습니다. 예: https://seccheck.company.internal

변경 사항은 감사로그에 기록됩니다.

서비스 관리자 설정 — 일반: 서비스명, 서비스 주소, 표시 시간대, 세션·보존 기간

일반 (general)

화면 이름	키	기본값	설명
서비스명	service_name	SecCheck	로그인 화면과 메일에 표시. 화면에서는 고정값으로 보이며 바꿀 수 없습니다
서비스 주소	base_url	(비어 있음)	알림 메일에 넣을 링크의 주소. 비우면 링크 없이 발송
표시 시간대	timezone	Asia/Seoul	화면·내보내기·기한 판정·요약 메일·심의번호 연도에 모두 적용. IANA 이름
세션 시간 (분)	session_minutes	480	15~10080
보존 기간 (일)	retention_days	1825	서버 로그와 인앱 알림 보존. 감사로그는 삭제하지 않음



서비스 관리자 설정 — 검토·승인: 승인 프로세스, 검토자 배정 필수, 본인 심의 처리 허용

검토·승인 (workflow)

화면 이름	키	기본값	설명
팀장/승인자 최종 승인 프로세스	approval_enabled	false	켜면 검토 완료 후 승인 대기 를 거쳐 승인자가 결재. 승인자가 지정되지 않은 심의는 제출되지 않음
검토자 배정 필수	require_reviewer_assignment	false	심의 생성 시 보안 담당자 지정을 요구
본인이 신청한 심의를 본인이 검토·승인 허용	allow_self_review	false	1인 운영용 예외. 켜면 SELF_REVIEW_FORBIDDEN · SELF_APPROVAL_FORBIDDEN 이 풀림

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

데모 관리자

정보보호팀

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

Keycloak / OIDC SSO 활성화

Issuer URL

https://keycloak.example/realms/company

Client ID

Client Secret

Keycloak confidential client secret

Callback URL

https://seccheck.example/api/v1/auth/oidc/callback

사용자명 Claim

preferred_username

신규 사용자 기본 역할

REQUESTER

그룹 매핑에 해당하지 않는 사용자에게 부여됩니다.

그룹 Claim

groups

비우면 groups

그룹 → 역할 매핑

+ 매핑 추가

지정하면 로그인할 때마다 IdP 그룹을 기준으로 역할을 다시 맞춥니다. 그룹에서 빠진 사용자는 해당 역할을 잃습니다. 비워 두면 기본 역할만 부여합니다. 시스템 관리자는 매핑할 수 없습니다.

Discovery 연결 테스트

변경 사항은 감사로그에 기록됩니다.

서비스 관리자 설정 — Keycloak OIDC: Issuer, Client, Callback, Claim 과 그룹 → 역할 매핑

Keycloak OIDC (oidc) — 연동 절차는 3-3 절.

화면 이름	키	기본값	설명
Keycloak / OIDC SSO 활성화	enabled	false	켜면 로그인 화면에 사내 SSO로 로그인 이 생김. issuer · client_id · redirect_url 이 비어 있으면 저 장이 거부됨(OIDC 활성화 시 issuer, client_id, redirect_url이 필요합니다.)
Issuer URL	issuer	(비어 있음)	Realm 주소. Discovery 연결 테스트 가여기의 .well-known/openid-configuration 을 읽음
Client ID	client_id	(비어 있음)	
Client Secret	client_secret	(비어 있음)	마스터 키로 암호화 저장되며 다시 표시되지 않음
Callback URL	redirect_url	(비어 있음)	https://<seccheck- host>/api/v1/auth/oidc/callback . Keycloak 의 Valid Redirect URIs 와 같아야 함
(화면에 없 음)	scopes	openid profile email	인가 요청의 scope . API 로만 바꿀 수 있음
사용자명 Claim	username_claim	preferred_username	토큰에서 아이디로 쓸 claim
그룹 Claim	groups_claim	(비어 있음)	비우면 groups
신규 사용자 기본 역할	default_role	REQUESTER	그룹 매핑에 해당하지 않는 사용자에게 부여. REQUESTER · CONTRIBUTOR · AUDITOR 중 하나
그룹 → 역할 매핑	role_mappings	(비어 있음)	[{"group": "...", "role": "..."}] . 하나라도 있으 면 로그인마다 역할을 다시 맞춤. SYSTEM_ADMIN 은 매핑 불가

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자 역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

최대 파일 크기(MB)

25

허용 확장자

pdf, png, jpg, jpeg, xlsx, xls, docx, zip, txt, json

ClamAV 악성코드 검사

ClamAV 주소

clamav:3310

연결 테스트

저장 전에 연결을 확인할 수 있습니다.

삭제 증거 보관(일)

90

논리 삭제 후 이 기간이 지나면 암호문 파일을 볼륨에서 제거합니다. 메타데이터와 감사 기록은 남습니다.

파일은 확장자와 실제 Magic/MIME을 함께 검증한 뒤 UUID 파일명으로 1MB 청크 AES-256-GCM 스트림으로 저장됩니다. 삭제된 증거의 암호문은 보관 기간이 지나면 매시간 유지보수 작업이 볼륨에서 제거하며, 파일명·해시·삭제자 기록은 감사 목적으로 보존됩니다.

○ 변경 사항은 감사로그에 기록됩니다.

서비스 관리자 설정 — 파일 보안: 허용 확장자, 최대 크기, ClamAV

파일 보안 (upload)

화면 이름	키	기본값	설명
최대 파일 크기(MB)	max_size_mb	25	증적 한 파일의 상한. 화면은 전송 전에 거절
허용 확장자	allowed_extensions	pdf png jpg jpeg xlsx xls docx zip txt json	확장자와 파일 내용(Magic/MIME)을 교차 검증
ClamAV 악성코드 검사	clamav_enabled	false	켜면 업로드 후 비동기 검사. 검사 전에는 내려받기·제출 제한
ClamAV 주소	clamav_address	(비어 있음)	clamav:3310 형식. 옆의 연결 테스트 가 clamd 에 PING 을 보냅니다. 켜기 전에 반드시 확인 — 주소가 틀리면 모든 증적이 검사 중 에 머물러 제출이 막힙니다
삭제 증거 보관(일)	deleted_evidence_retention_days	90	논리 삭제된 증거 파일을 볼륨에서 실제로 지우기까지의 기간. 메타데이터와 감사 기록은 남음

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

데모 관리자
정보보호팀

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

설정 저장

일반 검토·승인 **Keycloak OIDC** 파일 보안 접근 보안 알림

HTTPS 전용 Secure Cookie

/metrics를 인증 없이 공개

Prometheus 스크랩의 일반적인 방식입니다. 고면 사용자 수, 24시간 로그인 실패 수, 잠긴 계정 수 같은 값이 공개되지 않으며, 읽기 범위 API 키로 계속 수집할 수 있습니다.

분당 요청 제한

2000

장기 미접속 관리자 잠금(일)

90

분당 로그인 실패 제한

30

계정 잠금 실패 횟수

5

IP별 실패 시도만 계산합니다

계정 잠금 시간(분)

15

API 키 최대 유효기간(일)

365

유효 세션 만료(분)

0

0이면 제한 없음. 만료일을 바꾸고 발급하면 이 기간이 적용됩니다

관리자·검토자·승인자 계정에 일회용 코드(TOTP) 필수

신뢰 Reverse Proxy

서비스 관리자 설정 — 접근 보안: 요청 제한, 계정 잠금, 유효 만료, 신뢰 Proxy, TOTP 강제

접근 보안 (security)

화면 이름	키	기본값	설명
HTTPS 전용 Secure Cookie	cookie_secure	false	TLS 뒤에 두면 반드시 켭니다
CORS 허용 Origin	cors_origins	(비어 있음)	브라우저에서 API 를 직접 호출하는 다른 Origin
분당 요청 제한	rate_limit_per_minute	120	IP 별 전체 요청. 30~10000
분당 로그인 실패 제한	login_rate_limit_per_minute	30	IP 별 로그인 실패 횟수. 성공은 세지 않음
계정 잠금 실패 횟수	max_login_failures	5	연속 실패 시 잠금. 0 이면 잠금 없음
계정 잠금 시간 (분)	lockout_minutes	15	자동 해제까지의 시간
유희 세션 만료 (분)	idle_timeout_minutes	0	0 이면 세션 시간까지 유지. 값이 있으면 만료 2분 전에 계속 사용 을 묻습니다
장기 미접속 관리자 잠금(일)	inactive_admin_lock_days	90	관리자·체크리스트 관리자·보안 담당자·승인자 계정이 이 기간 로그인하지 않았으면 다음 로그인 시도에서 비활성화하고 시스템 관리자에게 권한 계정 자동 잠금 알림을 보냅니다. 사용자 · 역할 의 필터로 대상 계정을 미리 볼 수 있습니다
API 키 최대 유효 기간(일)	api_key_max_days	365	만료일 없이 발급하면 이 기간 적용. 0 이면 제한 없음
신뢰 Reverse Proxy	trusted_proxies	(비어 있음)	X-Forwarded-For 를 신뢰할 Proxy IP/CIDR. Proxy 뒤에서는 필수 — 비우면 모든 요청이 Proxy IP 하나로 집계됩니다
관리자·검토자·승인자 계정에 일회용 코드(TOTP) 필수	require_totp_for_admins	false	대상 계정은 등록 전까지 계정 보안 화면 외 API 가 403
/metrics를 인증 없이 공개	metrics_public	true	고면 읽기 범위 API 키로만 수집

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

이메일 알림 활성화

SMTP 호스트

SMTP 포트

전송 보안

SMTP 사용자

SMTP 비밀번호

발신 주소

일일 요약 발송 시각

테스트 메일 보내기

이메일은 PostgreSQL 작업 큐에서 제시되며, 실패한 작업은 관리자 > 작업 큐에서 확인하고 다시 실행할 수 있습니다. 사용자는 알림 화면의 수신 설정에서 유형별로 이메일을 끄거나 하루 요약으로 바꿀 수 있습니다.

서비스 관리자 설정 — 알림: SMTP와 일일 요약 시각, 테스트 메일

알림 (notification)

화면 이름	키	기본값	설명
이메일 알림 활성화	email_enabled	false	서비스 전체 스위치. 꺼져 있으면 인앱 알림만
SMTP 호스트 / 포트	smtp_host / smtp_port	(비어 있음) / 25	
SMTP 사용자 / 비밀번호	smtp_username / smtp_password	(비어 있음)	비밀번호는 마스터 키로 암호화 저장되며 다시 표시되지 않음
전송 보안	smtp_tls_mode	starttls	starttls · implicit TLS · 없음
발신 주소	from	(비어 있음)	
일일 요약 발송 시각	digest_hour	8	0~23. 요약 수신자에게 하루 한 번

테스트 메일 보내기 는 저장된 설정으로 본인에게 1통을 보냅니다. 운영 전에 반드시 한 번 확인하십시오.

3-3. Keycloak OIDC 연동

1. Keycloak 에서 Client 를 만듭니다: Client Type `OpenID Connect` , Client Authentication `ON` , Standard Flow `ON` , Valid Redirect URIs `https://<seccheck-host>/api/v1/auth/oidc/callback` .

2. 그룹으로 역할을 주려면 Client 에 **group membership mapper** 를 추가해 토큰에 `groups claim` 이 들어가게 합니다.

3. 서비스 설정 > Keycloak OIDC :

- Keycloak / OIDC SSO 활성화 ON
- Issuer URL `https://keycloak.example.com/realms/enterprise`
- Client ID, Client Secret (암호화 저장)
- Callback URL `https://seccheck.example.com/api/v1/auth/oidc/callback`
- 사용자명 Claim `preferred_username`, 그룹 Claim `groups`
- 신규 사용자 기본 역할 **REQUESTER** (매핑에 해당하지 않는 사용자에게 부여)
- 그룹 → 역할 매핑

4. Discovery 연결 테스트 로 Issuer 에 닿는지 확인한 뒤 저장합니다.

그룹 매핑을 하나라도 지정하면 **로그인할 때마다** IdP 그룹 기준으로 역할을 다시 맞춥니다. 그룹에서 빠지면 다음 로그인에 역할을 잃습니다. 매핑을 쓰지 않으면 최초 로그인에 기본 역할만 주고 이후에는 손대지 않으므로 퇴사자 권한 회수를 사람이 해야 합니다. `SYSTEM_ADMIN` 은 그룹으로 부여할 수 없습니다 — 디렉터리 그룹을 편집할 수 있는 사람이 감사 시스템의 관리자가 되는 경로를 만들지 않기 위해서입니다. 역할이 실제로 바뀐 로그인은 디렉터리 역할 동기화 감사 이벤트로, 토큰에서 읽은 그룹 목록은 서버 로그 `oidc` 구성요소의 `directory groups received` 로 남습니다.

4. 계정과 권한

4-1. 역할

역할 코드	화면 이름	할 수 있는 일
<code>SYSTEM_ADMIN</code>	시스템 관리자	서비스 설정, 사용자·역할, 감사로그·체인 검증, 서버 로그, 작업 큐, API 키, 시스템 정보, 리포트. 개별 심의 내용은 보안 담당자·감사자 역할이 있어야 열람
<code>TEMPLATE_ADMIN</code>	체크리스트 관리자	템플릿 생성·편집·게시·사용 중지, Excel 가져오기, Rule 시뮬레이터, Security Control, 자동 배정 조정
<code>SECURITY_REVIEWER</code>	보안 담당자	보안 검토 Queue, 검토 시작, 항목 판정, 보완 요청·이행 확인, 검토 완료, 반려 심의 다시 열기, 결재 요청 회수, 리포트
<code>APPROVER</code>	승인자	승인 대기 심의의 최종 승인·반려, 리포트
<code>REQUESTER</code>	심의 요청자	심의 생성·작성·증적 업로드·제출·재제출·취소·재심의 복사
<code>CONTRIBUTOR</code>	공동 작성자	참여자로 초대된 심의의 작성·증적 첨부
<code>AUDITOR</code>	감사자	모든 심의와 감사로그 읽기 전용, Security Control, 리포트

메뉴는 가진 역할에 맞게만 보입니다. 검토자와 승인자는 **두 명 이상** 두는 것을 권장합니다 — 보유자가 한 명뿐인 역할은 시스템 정보 의 역할 보유자 표에 1명뿐 으로 표시되며, 그 사람이 신청한 심의는 아무도 처리할 수 없습니다.

4-2. 사용자·역할 화면

사용자 및 역할
RBAC 역할을 조합하고 비활성 계정의 세션을 즉시 종료하며, 로그인 실패로 잠긴 계정을 해제하거나 임시 비밀번호를 발급합니다.

검색: 이름, 아이디, 이메일, 부서 검색

전체 계정

5 / 5명

사용자	부서	인증	역할	마지막 접속	상태	관리
김보안 kim · kim@example.com	정보보 호팀	LOCAL	보안 담당자, 체크리스트 관리자	기록 없음 · 2026. 09. 11. 생성	활성 임시 비밀번호	역할, 비밀번호, 업무 인계, 삭제
데모 관리자 admin · admin@example.com	정보보 호팀	LOCAL	승인자, 감사자, 심의 요청자, 보안 담당자, 시스템 관리자, 체크리스트 관리자	2026. 09. 11. 오늘	활성	역할, 비밀번호, 업무 인계, 삭제
박감사 park · park@example.com	감사실	LOCAL	감사자	기록 없음 · 2026. 09. 11. 생성	활성 임시 비밀번호	역할, 비밀번호, 업무 인계, 삭제
이송인 lee · lee@example.com	정보보 호팀	LOCAL	승인자	기록 없음 · 2026. 09. 11. 생성	활성 임시 비밀번호	역할, 비밀번호, 업무 인계, 삭제
홍길동 hong · hong@example.com	플랫폼 개발팀	LOCAL	심의 요청자	기록 없음 · 2026. 09. 11. 생성	활성 임시 비밀번호	역할, 비밀번호, 업무 인계, 삭제

사용자 및 역할 — 계정 검색, 역할 배치, 잠금·임시 비밀번호 상태, 업무 인계

- 로컬 사용자 (+ 아이콘 버튼): 아이디·이름·이메일·부서·역할과 임시 비밀번호로 계정을 만듭니다. 비밀번호 정책 (12자 이상, 혼한 값·아이디· seccheck 포함 불가)은 여기에도 적용됩니다.
- 역할 : 역할을 더하거나 뺍니다. 감사로그에 남습니다.
- 비밀번호 : 임시 비밀번호를 발급합니다(임의 생성 으로 안전한 값). 발급하면 그 사용자의 세션이 모두 끝나고 잠금도 풀립니다. SSO 계정에는 쓸 수 없습니다.
- 임시 비밀번호 배치: 관리자가 정해 준 값으로 아직 바꾸지 않은 계정. 그 계정은 바꾸기 전까지 다른 화면과 API 를 쓸 수 없습니다(403 PASSWORD_CHANGE_REQUIRED). 상단 필터 임시 비밀번호 미변경 으로 모아 봅니다.
- 잠금 해제 : 로그인 실패로 잠긴 계정을 즉시 풀니다. 잠금은 신규 로그인만 막고 열린 세션은 끊지 않습니다.
- 코드 초기화 : 기기를 잃은 사용자의 2단계 인증을 해제하고 세션을 모두 끝냅니다. 다시 등록하도록 안내하십시오.
- 업무 인계 : 그 계정이 맡고 있는 모든 심의(요청자·검토자·승인자 자리)와 배정된 항목·보안 요청을 한 번에 넘깁니다. 넘겨받을 사람에게 역할이 없거나 본인 심의를 본인이 검토하게 되는 자리는 이유와 함께 남겨 둡니다. 담당 업무 일괄 인계 감사 이벤트로 남습니다.
- 비활성화(맨 오른쪽): 누르기 전에 그 계정이 아직 맡고 있는 진행 중 심의와 미이행 후속조치 건수를 먼저 보여 줍니다. 비활성화해도 자리는 비워지지 않으므로 남은 것이 있으면 먼저 인계하십시오. 비활성화된 계정의 API 키는 폐기하지 않아도 인증이 거부됩니다. 현재 로그인한 계정은 비활성화할 수 없습니다.

역할을 회수하거나 계정을 비활성화하면 그 사람이 담당하던 심의는 담당자 없는 심의로 취급되어 다른 검토자·승인자의 내 차례 에 다시 오르고, 심의 상세의 검토 이어받기 로 넘겨받을 수 있습니다. 심의가 멈추지는 않습니다.

4-3. API 키

API 키

설치 전체의 기계 자격증명을 확인하고 폐기합니다

데모 관리자
정보보호팀

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

API 키

설치 전체의 기계 자격증명과 소유자, 마지막 사용 시작입니다. 계정을 비활성화하면 그 계정의 키도 즉시 통하지 않습니다.

사용 가능한 키

▼

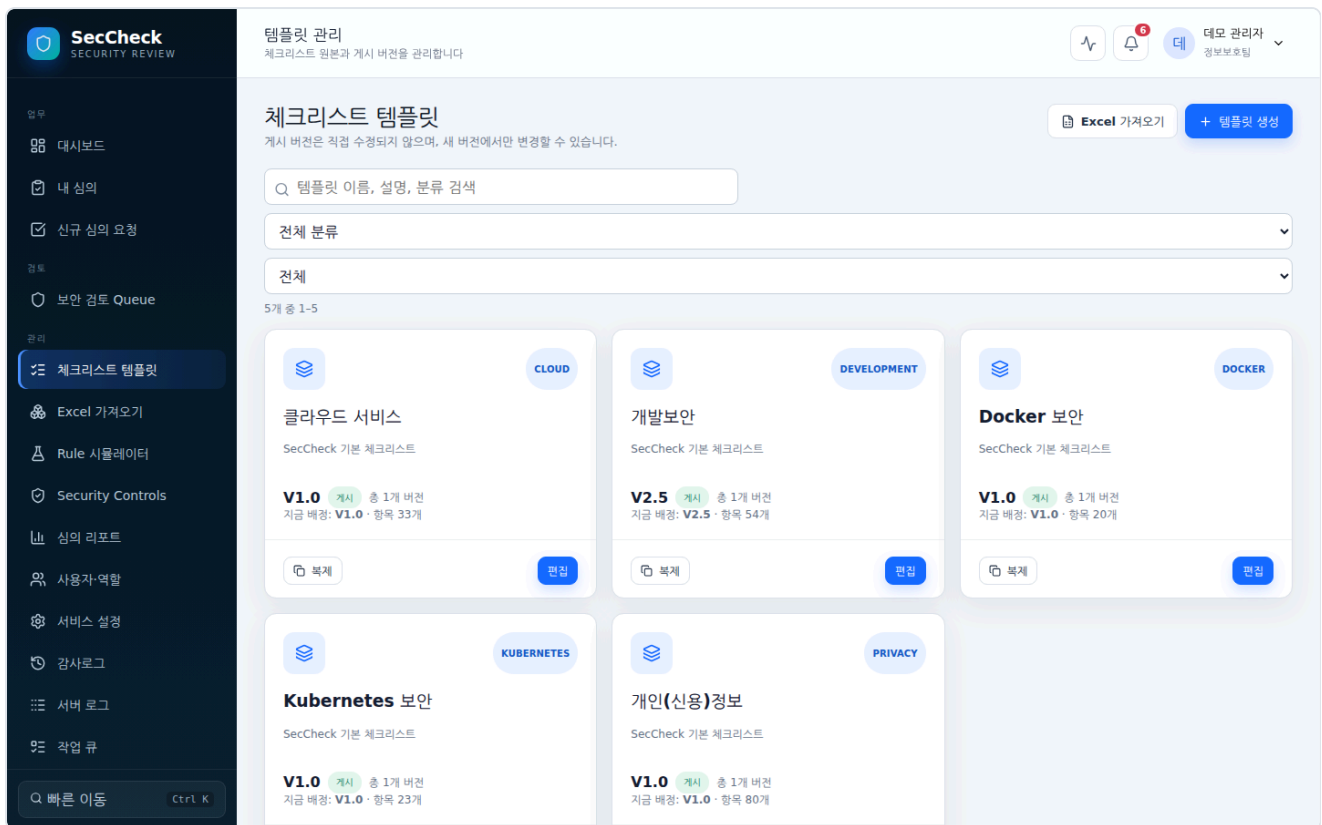
1개 표시

소유자	키	범위	마지막 사용	만료	상태
데모 관리자 admin · 정보보호팀	CI 파이프라인 연동 sck_Mp65d8P_...	read	사용된 적 없음	2027. 09. 11.	사용 가능 폐기

API 키 — 설치 전체의 기계 자격증명: 소유자, 범위, 마지막 사용, 만료

사용자는 개인 키 관리 에서 자기 키를 만들고, 관리자는 API 키 에서 설치 전체의 키를 봅니다. 소유자, 이름과 접두사, 범위(read / read:write), 마지막 사용 시각, 만료일, 상태. 폐기 는 다른 사용자의 키에도 적용되며 즉시 효력이 생기고 REVOKE_API_KEY 감사 이벤트로 남고 소유자에게 알림이 갑니다. 한 번도 쓰이지 않은 키와 오래 쓰이지 않은 키는 접근 권한 검토의 우선 정리 대상입니다.

4-4. 체크리스트 관리 (TEMPLATE_ADMIN)



체크리스트 템플릿 — 기본 탑재 템플릿과 지금 배정되는 버전·항목 수

- 카드의 지금 배정: <버전> · 항목 N개 가 오늘 새 심의가 실제로 받는 체크리스트입니다. 사용 불가 항목 N건 배지는 규칙 오류나 선택지 없는 선택형 항목으로 어느 심의에도 배정되지 않는 항목입니다.
- 게시된 버전은 수정할 수 없습니다. 고치려면 새 버전을 만들어 게시하고 이전 버전을 사용 중지 합니다. **사용 중인 템플릿은 게시 버전을 최소 하나 유지해야 하며 마지막 게시 버전을 중지하려 하면 거절됩니다** (LAST_PUBLISHED_VERSION). 더 이상 적용하지 않을 체크리스트는 템플릿 사용 안 함 으로 뺍니다.
- 게시 시 모든 항목의 적용 규칙과 선택지를 검사해 문제 항목과 사유를 알려 줍니다(INVALID_RULE).

SecCheck

SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자 역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

템플릿 편집

초안 항목과 버전을 관리합니다

6

데

데모 관리자

정보보호팀

← 템플릿

+ 새 버전

버전 비교

사용 중지

템플릿 사용 안 함

클라우드 서비스

CLOUD · SecCheck 기본 체크리스트

V1.0 · PUBLISHED

게시

기본 체크리스트 자동 등록

변경 이력

Q 항목코드, 섹션, 보안요건, 질문, 가이드 검색

전체 중요도

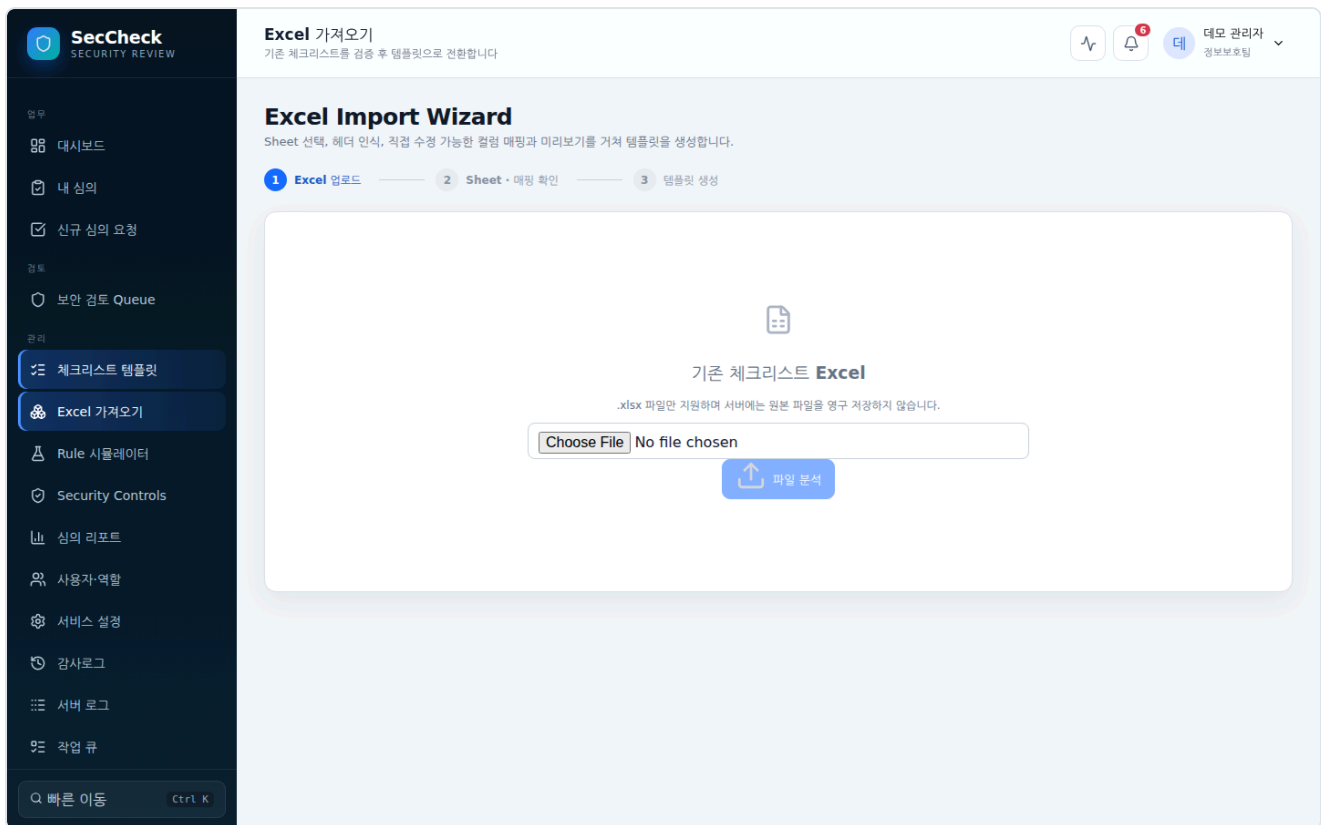
33 / 33개 항목

순서	코드	섹션	보안요건	중요도	입력 유형	필수
1	CLOUD-001	공통	바이러스, 웜, 트로이목마 등의 악성코드 탐지 및 차단 기술 적용하고 있는가? 바이러스, 웜, 트로이목마 등의 악성코드 탐지 및 차단 기술 적용하고 있는가?	MEDIUM	YNNA	필수
2	CLOUD-002	공통	가상환경에서 이상징후 발견 시 사용중지 및 격리 체계 마련하고 있는가? 가상환경에서 이상징후 발견 시 사용중지 및 격리 체계 마련하고 있는가?	MEDIUM	YNNA	필수
3	CLOUD-003	가상화보안	가상자원의 생성, 변경, 회수 등에 대한 관리방안 마련하고 있는가? 가상자원의 생성, 변경, 회수 등에 대한 관리방안 마련하고 있는가?	MEDIUM	YNNA	필수
4	CLOUD-004	가상화보안	가상자원에 대한 무결성 보장을 위한 보호조치 및 변경 내역 모니터링을 하고 있는가? 가상자원에 대한 무결성 보장을 위한 보호조치 및 변경 내역 모니터링을 하고 있는가?	MEDIUM	YNNA	필수
5	CLOUD-005	가상화보안	호스트OS 및 가상화관리 소프트웨어 모니터링 및 패치를 포함한 악성코드 방지대책 마련하고 있는가? 호스트OS 및 가상화관리 소프트웨어 모니터링 및 패치를 포함한 악성코드 방지대책 마련하고 있는가?	MEDIUM	YNNA	필수
6	CLOUD-006	가상화보안	가상화 실행 이력의 안전한 저장·관리 방안을 수립하고 있는가? 가상화 실행 이력의 안전한 저장·관리 방안을 수립하고 있는가?	MEDIUM	YNNA	필수
7	CLOUD-007	가상화보안	가상화 OS의 내/외부 데이터 이용에 대한 로그 관리를 하고 있는가? 가상화 OS의 내/외부 데이터 이용에 대한 로그 관리를 하고 있는가?	MEDIUM	YNNA	필수

하드웨어, 가상 이미지, 가상화 관리 소프트웨어(하이퍼바이저 등)에 대한 잠재적 위협을 고려하여 취약점

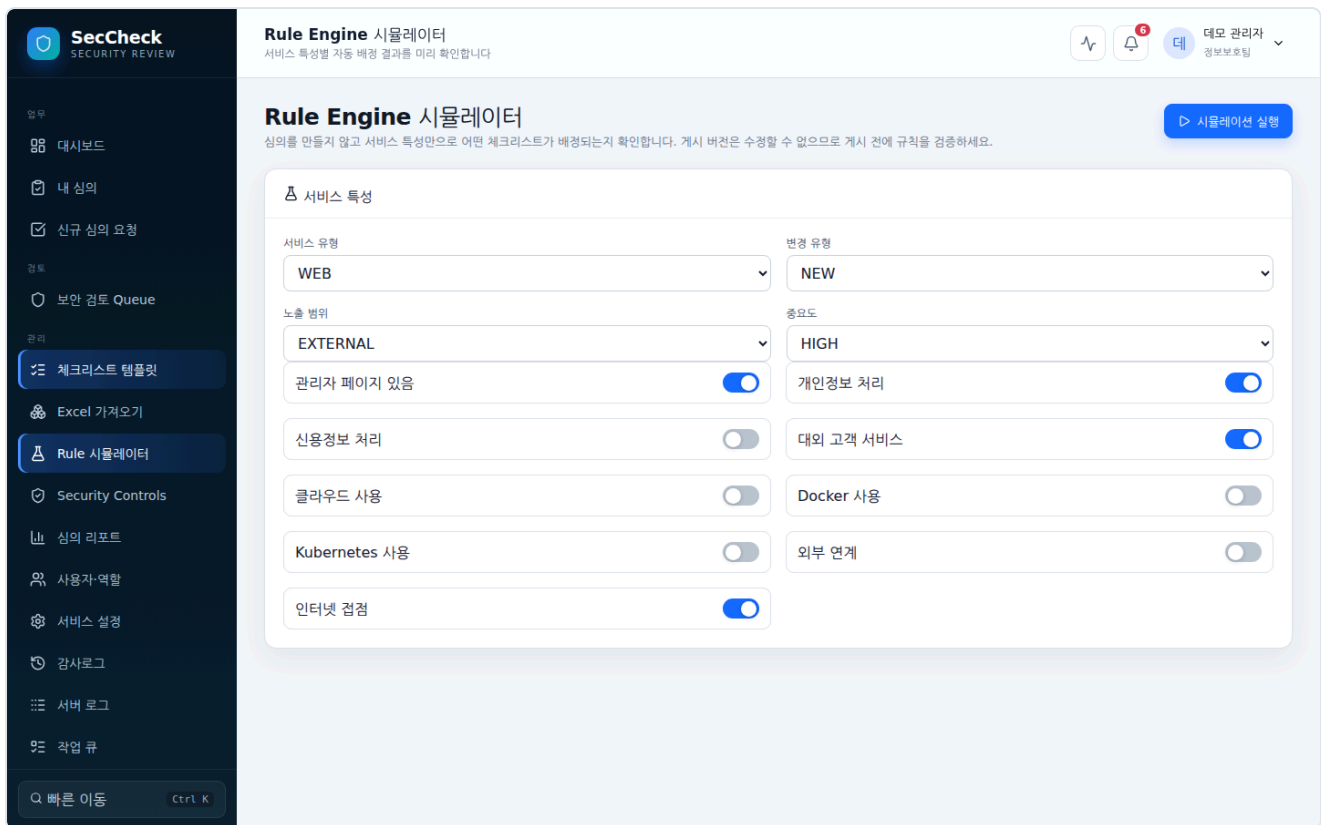
템플릿 상세 — 버전, 섹션과 항목, 적용 규칙, 게시·사용 중지

항목코드는 한 버전 안에서 유일해야 하고 40자, 제목 300자, 섹션 100자, 질문·안내·예시 각 4,000자, 근거 2,000자입니다. 항목은 심의마다 스냅샷으로 복사되므로 한 번 길게 넣은 값이 이후 모든 심의에 복제됩니다.



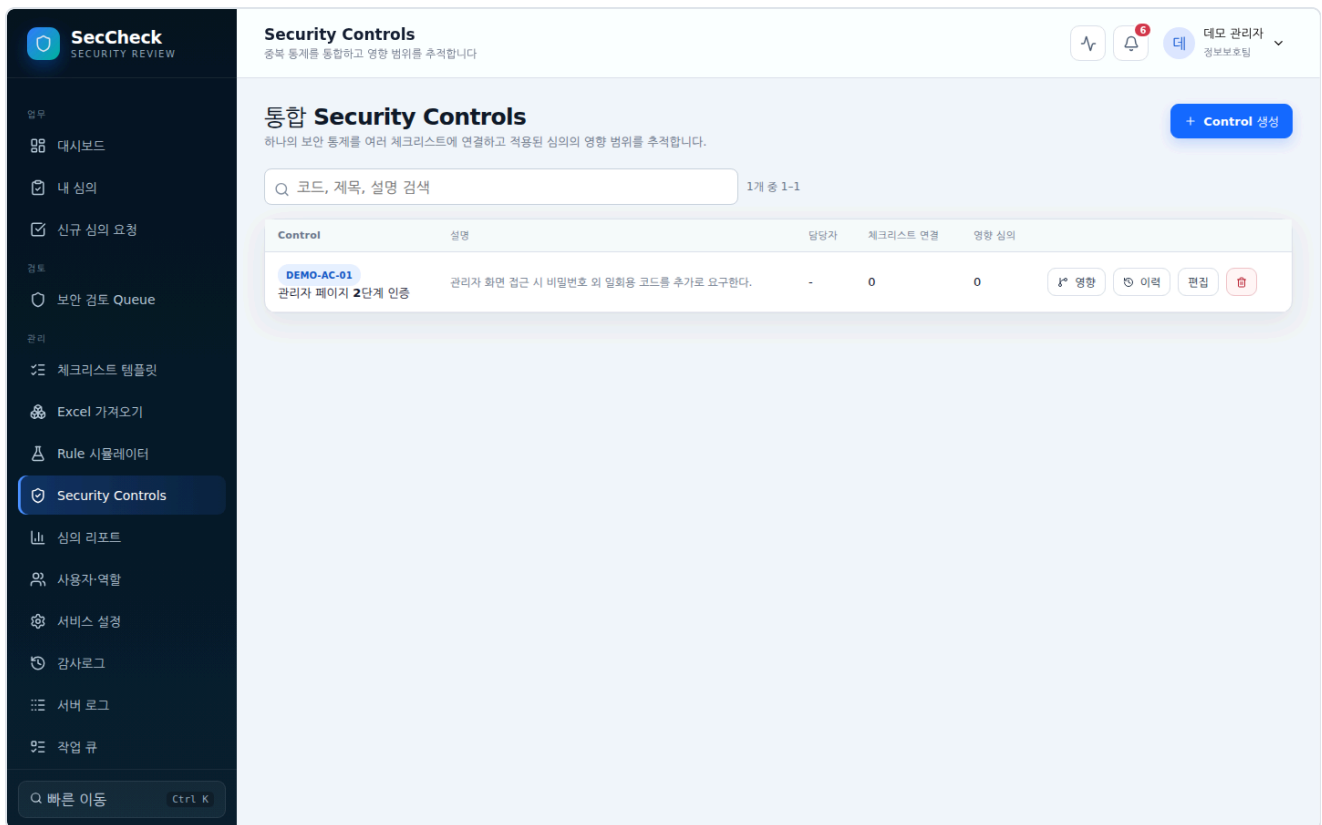
Excel 가져오기 — 시트와 헤더를 자동 인식하고 매핑을 확인한 뒤 템플릿으로 전환

.xlsx 를 올리면 시트별 헤더와 컬럼 매핑을 자동 인식하고, 미리보기에서 건너뛴 행·자동 부여될 코드·잘릴 값·중복 코드 (-DUP2)·매핑되지 않은 컬럼을 행 번호와 함께 알려 줍니다. 게시하거나 심의에 쓰인 뒤에는 삭제할 수 없으니 게시 전에 확인하십시오.

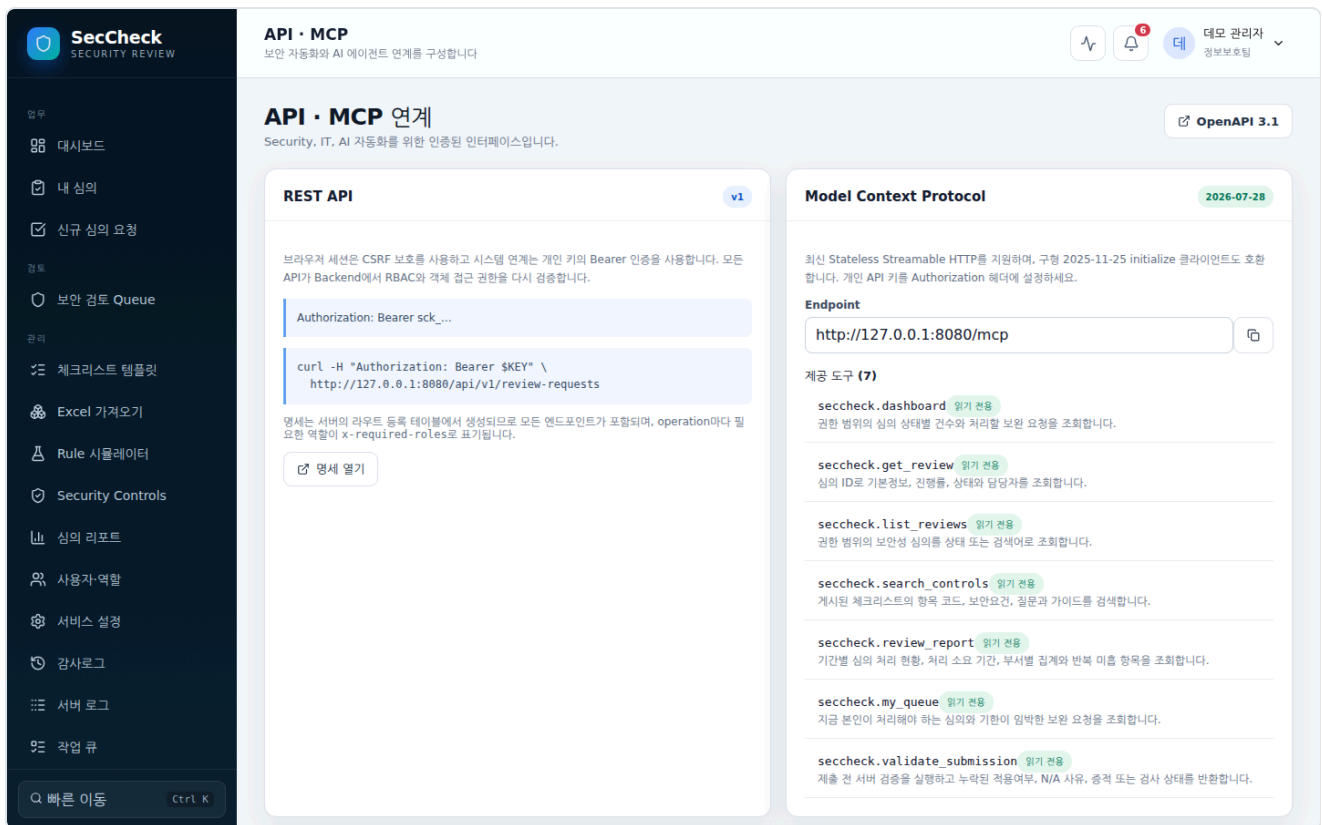


Rule Engine 시뮬레이터 — 서비스 특성을 넣어 배정·제외 항목과 규칙 오류를 미리 본다

심의를 만들지 않고 배정 결과를 계산합니다. 제외 사유를 **분류 불일치**와 **적용 규칙 불만족**으로 구분하고, 맨 위에 **적용 규칙 오류** 표가 나옵니다.



여러 템플릿에 흩어진 같은 통제를 하나의 Control 로 묶고, 연결된 체크리스트와 영향 심의 범위를 봅니다. 이력 은 감사 로그를 그 대상으로 좁혀 엽니다.



API · MCP 연계 — REST 명세와 MCP 도구 목록

GET /api/openapi.json 이 OpenAPI 3.1 명세, POST /mcp 가 MCP 2026-07-28 Streamable HTTP 엔드포인트입니다. 인증은 API 키(Authorization: Bearer)입니다. 자세한 내용은 [api-guide.md](#).

5. 운영

5-1. 상태 점검 엔드포인트

경로	메서드	인증	용도
/health	GET	없음	프로세스 생존. compose healthcheck 는 seccheck healthcheck 로 이 경로를 호출
/ready	GET	없음	데이터베이스 포함 준비 상태. 배포·업그레이드 뒤 확인
/metrics	GET	기본 없음 (metrics_public)	Prometheus 지표. 수집 쿼리가 실패하면 0 대신 503
/api/v1/admin/system	GET	SYSTEM_ADMIN	시스템 정보 화면의 원본

경보 기준은 `seccheck_maintenance_last_run_seconds > 10800`, `seccheck_jobs_failed > 0`, `seccheck_audit_write_failures > 0`, `seccheck_evidence_unreadable > 0`, `seccheck_storage_writable == 0` 이 최소입니다. 전체 지표는 [operations.md](#).

5-2. 시스템 정보

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

시스템 정보

버전·스키마·저장 공간을 확인합니다

시스템 정보

업그레이드와 장애 대응에서 먼저 확인하는 값입니다.

627786.1 MB

증적 볼륨 남은 공간

13 MB

데이터베이스 크기

정기 점검

정상

마지막 완료

2026. 09. 11. 오후 10:26

수행 항목

기한 알림 · 심의 정제 알림 · 증적 무결성 표본 검사 · 감사로그 체인 검증 · 보존 기간 정리 (매시간)

증적 저장소

정상

경로

data/evidence

쓰기 가능

예

거장된 증적

0건 · 0 B (파기된 버전 제외)

남은 공간

627786.1 MB / 1031018.4 MB (61%)

증적 무결성

확인 마책 없음

확인한 증적

0건 · 미확인 0건

가장 오래된 확인

-

유지보수 스캔이 매시 가장 오래 확인하지 않은 증적을 복호화해 크기와 해시를 대조합니다. 실패한 파일은 백업본 복구가 필요하며, 전체 검증은 seccheck verify-evidence로 실행합니다.

시스템 정보 — 버전, 스키마, 역할 보유자, 증적 저장소와 무결성, 정기 점검

업그레이드 직후와 장애 대응 때 가장 먼저 여는 화면입니다. 버전, 적용된 스키마 버전, Go 런타임, 데이터 규모, 역할별 활성 보유자 수, 증적 볼륨의 남은 공간과 쓰기 가능 여부, **증적 무결성**(되임기 확인 건수와 실패 파일 최대 10건), PDF 용 한글 글꼴 존재 여부, **정기 점검** 마지막 완료 시각(3시간 넘게 없으면 붉은 배지).

5-3. 로그

로그	어디에	무엇
서버 로그	서버 로그 화면 (DB 저장)	요청 ID 기반 구조화 로그. component (admin , api , audit , auth , bootstrap , evidence , export , maintenance , notification , oidc , review , scanner) 와 필드로 검색
컨테이너 표준 출력	docker compose logs seccheck	기동·종료, 그리고 DB 에 기록할 수 없을 때 밀려 나오는 줄. 로그 수집기가 함께 모으도록 구성
감사로그	감사로그 화면	해시 체인으로 묶인 주요 행위. 자동 삭제하지 않음

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자 역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서버 로그

구조화된 애플리케이션 로그를 확인합니다

Q 메시지, 구성요소, 요청 ID, 경로 검색

전체 레벨

10초 자동 새로고침

시각

레벨

구성요소

메시지

2026. 09. 11. 오후 10:26

INFO

http

HTTP request {"duration_ms":1,"method":"GET","path":"/api/v1/notifications/unread-count","status":200}

2026. 09. 11. 오후 10:26

INFO

http

HTTP request {"duration_ms":3,"method":"GET","path":"/api/v1/me","status":200}

2026. 09. 11. 오후 10:26

INFO

http

HTTP request {"duration_ms":1,"method":"GET","path":"/api/v1/public/config","status":200}

2026. 09. 11. 오후 10:26

INFO

http

HTTP request {"duration_ms":3,"method":"GET","path":"/api/v1/admin/audit","status":200}

2026. 09. 11. 오후 10:26

INFO

http

HTTP request {"duration_ms":2,"method":"GET","path":"/api/v1/notifications/unread-count","status":200}

2026. 09. 11. 오후 10:26

INFO

http

HTTP request {"duration_ms":2,"method":"GET","path":"/api/v1/me","status":200}

서버 로그 — 구성요소·요청 ID·필드로 검색하고 10초 자동 새로고침

감사로그의 요청 ID 를 서버 로그 검색창에 붙여 넣으면 같은 요청의 처리 결과가 이어집니다. 500 응답은 `component=api` 에 `fields.code` · `fields.error` 로 원인이 남습니다. 서버 로그와 작업 큐는 최근 200건까지만 보여 주므로 오래된 것은 조건을 좁혀 찾습니다.

감사로그

중요 행위의 해시 체인 이력을 확인합니다

데모 관리자
정보보호팀

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동 Ctrl K

감사로그

이전 이벤트 해시를 연결한 위변조 탐지 체인입니다. 애플리케이션에서 수정·삭제 API를 제공하지 않습니다.

CSV 내보내기

체인 검증

전체 재검증

이벤트 유형

Q 목록에서 고르거나 직접 입력

앞부분만 입력해도 됩니다. 예: LOGIN

사용자 / 접속 IP

이름 또는 IP 일부

대상 ID

심의-Control-템플릿 ID

표의 대상 값을 누르면 그 대상의 이력이 남습니다.

이벤트 ID

감사 이벤트 ID

무결성 실패 알림이 가리키는 그 이벤트만 봅니다.

결과

전체

거부된 시도만 모아 봅니다.

시작일

mm/dd/yyyy

종료일

mm/dd/yyyy

표시 건수

200

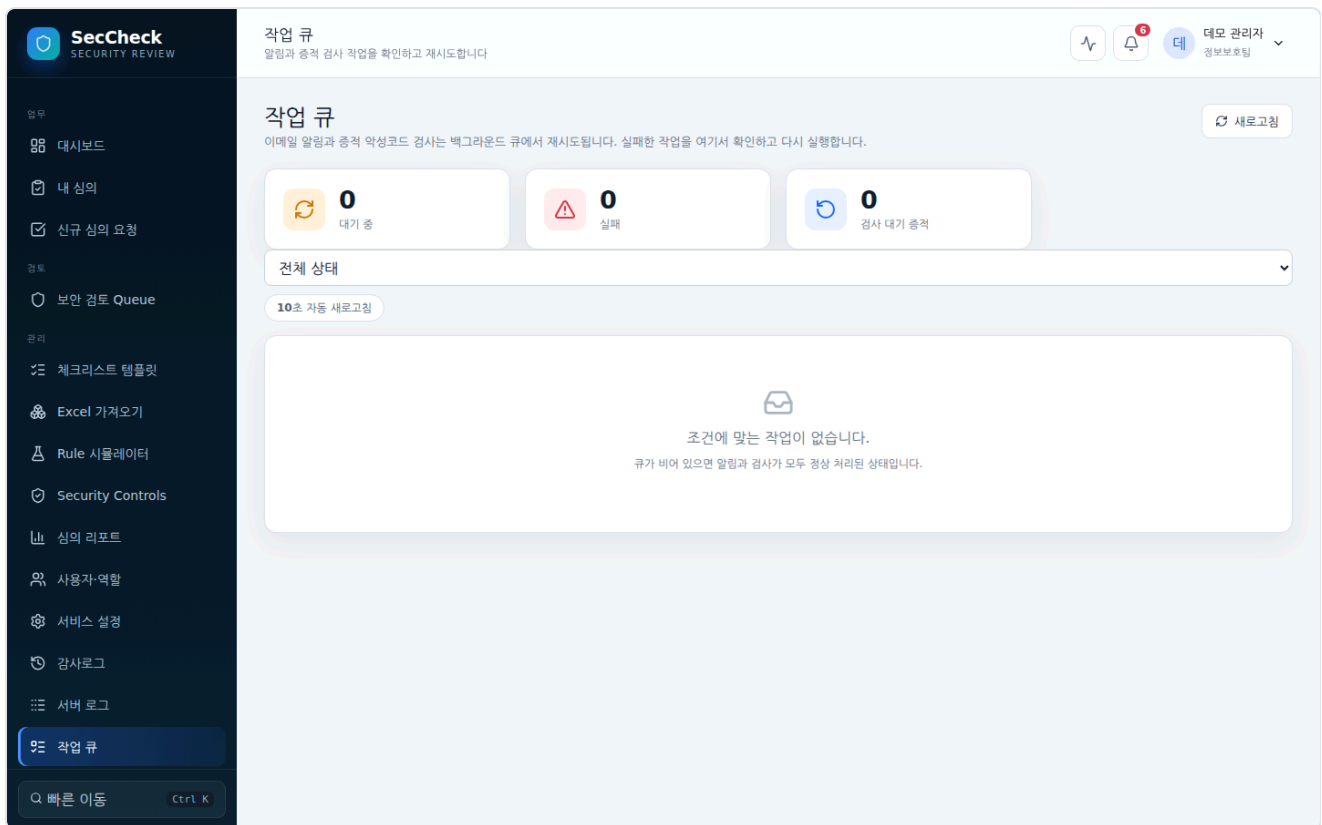
필터 초기화

시작	이벤트	사용자 / IP	대상	결과	해시
2026. 09. 11. 오후 10:26	심의 조회 VIEW_SUBMISSION	데모 관리자 127.0.0.1	REVIEW_REQUEST 7a14d6aa-fd0c-4e6f-a844-171095237aab	SUCCESS	0c456ba11688...
2026. 09. 11. 오후 10:26	심의 조회 VIEW_SUBMISSION	데모 관리자 127.0.0.1	REVIEW_REQUEST 3b1a2819-debd-4a36-93e1-42416c454564	SUCCESS	14e26e197722...
2026. 09. 11. 오후 10:25	심의 조회 VIEW_SUBMISSION	데모 관리자 127.0.0.1	REVIEW_REQUEST 27aeb58a-2174-4d71-8725-74e7d5c4fc6d	SUCCESS	8391a7898a4a...
2026. 09. 11. 오후 10:25	심의 조회	데모 관리자	REVIEW_REQUEST	SUCCESS	5f6c-1a222...

감사로그 — 이벤트·사용자·기간 필터, 상세의 변경 전후 값과 해시, 체인 검증

- 필터: 이벤트 유형(앞부분만 입력해도 매칭), 사용자명 또는 IP, 기간, 결과(FAILURE 만 보기), 이벤트 ID, 대상.
- 배지를 누르면 변경 전후 값, 요청 ID, 이전 해시와 이벤트 해시가 보입니다. 더 보기 로 200건씩 이어 읽습니다.
- CSV 내보내기 는 현재 필터로 최대 50,000행. 내보내기 자체가 EXPORT_AUDIT 로 남습니다. = + - @ 로 시작하는 값은 작은따옴표를 앞에 붙여 Excel 수식 해석을 막습니다.
- 체인 검증 은 마지막 검증 지점 이후를, 전체 재검증 은 처음부터 다시 확인합니다. 서비스도 매시간 자동으로 검증하며 실패하면 활성 시스템 관리자 전원에게 감사로그 무결성 실패 알림이 갑니다(6시간에 한 번으로 제한).

5-4. 작업 큐



작업 큐 — 이메일 발송과 증적 검사 작업의 상태, 재시도

유형	내용	실패 시
SEND_EMAIL	인앱 알림의 이메일 발송	SMTP 오류는 5회 재시도 후 FAILED . 수신자 이메일이 없거나 발송이 꺼진 경우처럼 재시도로 해결되지 않는 것은 재시도 없이 COMPLETED 로 끝내고 사유를 마지막 오류 에 남김
SCAN_EVIDENCE	증적 악성코드 검사	5회 재시도 후 FAILED , 증적은 ERROR . 재시도하면 PENDING 으로 복귀

상태 필터와 10초 자동 새로고침 , 개별 재시도와 실패 전체 재시도가 있습니다. 검사 대기 증적 카드가 줄지 않으면 clamd 연결을 먼저 확인하십시오. 재시작으로 RUNNING 에 남은 작업은 매시간 정기 점검이 15분 이상 된 것을 큐에 되돌립니다. 재시도를 모두 소진한 작업이 생기면 시스템 관리자에게 작업 재시도 소진 알림이 옵니다.

5-5. 정기 점검 (매시간)

서비스 시작 1분 뒤부터 매시간 실행되며 별도 cron 이 필요 없습니다.

- 기한 알림(보완 조치·후속조치·오픈 예정일 임박·심의 정체), 알림 요약 발송
- 감사로그 체인 증분 검증
- 가장 오래 확인하지 않은 증적 20건 되읽기(증적 무결성 확인 실패 알림)
- 만료 세션·OIDC state, 완료 7일·실패 90일 지난 작업, retention_days 지난 서버 로그·알림, 잠금 시간 지난 실패 카운터 정리(5,000행 단위)
- deleted_evidence_retention_days 지난 삭제 증적의 실제 파기

- 15분 이상 RUNNING 인 작업 되돌리기, API 키 만료 안내

멈추면 위의 모든 것이 함께 멈춥니다. 시스템 정보 > 정기 점검 과 seccheck_maintenance_last_run_seconds 로 감시하십시오.

5-6. 백업

세 가지를 같은 시점으로 함께 보관합니다.

대상	방법	비고
PostgreSQL	일간 full + WAL/PITR. <code>pg_dump -Fc -U seccheck seccheck > seccheck-\$(date +%F).dump</code>	설정·감사로그·작업 큐·서버 로그가 모두 여기 있음
증적 볼륨 /app/data	<code>docker run --rm -v seccheck-data:/data -v "\$PWD":/backup alpine tar czf /backup/seccheck-data-\$(date +%F).tgz -C /data .</code>	암호문이므로 백업 매체가 유출돼도 ENCRYPTION_KEY 없이는 열리지 않음
ENCRYPTION_KEY	데이터와 별도 보관, 이중 통제	없으면 증적 복구 불가

복구 훈련은 격리 환경에서 실제 로그인, 목록, 증적 다운로드와 SHA-256 대조, PDF/Excel 내보내기까지 확인하고, 백업 식별자·RPO/RTO·검증한 심의/증적 ID·수행자를 기록합니다.

5-7. 복구

```
docker compose down
pg_restore -U seccheck -d seccheck --clean --if-exists seccheck-2026-09-11.dump
docker run --rm -v seccheck-data:/data -v "$PWD":/backup alpine sh -c 'rm -rf /data/* && tar xzf /backup/seccheck-data-$(date +%F).tgz -C /data .'
docker compose up -d
docker compose exec seccheck /app/seccheck verify-evidence --sample 50 # 전체는 --sample 없이. 실패 시 종료
```

복구 뒤에는 감사로그 화면에서 전체 재검증 을 한 번 실행합니다.

5-8. 업그레이드와 되돌리기

1. CHANGELOG.md 에서 대상 버전까지의 스키마·설정 항목을 읽습니다. 인덱스 추가 마이그레이션은 쓰기 잠금을 잡으므로 데이터가 많은 설치는 점검 시간에 합니다.
2. 5-6 절대로 백업합니다. 마이그레이션은 되돌리지 않으므로 되돌리는 방법은 백업 복구입니다.
3. 새 이미지를 적재하고 compose.yaml 의 image: 태그를 새 태그로 바꿉니다. 2-4 절에 실은 본문은 이 가이드가 쓰인 버전의 것이므로, 새 릴리즈의 가이드에 실린 본문과 달라졌는지도 함께 봅니다.

```
docker load -i seccheck-<새 태그>.tar.gz
sed -i 's/seccheck:v1.0.144/seccheck:<새 태그>/' compose.yaml
docker compose up -d
```

4. 기동 로그에서 SecCheck started 를 확인하고 /ready 가 200 인지, 시스템 정보 의 버전과 스키마 버전이 기대와 같은지 봅니다.

```
docker compose exec seccheck /app/seccheck verify-schema # 데이터베이스가 이 빌드와 맞는지. --json 가
```

5. 되돌릴 때: docker compose down → 이전 태그로 image: 복원 → 백업한 데이터베이스와 볼륨 복구(5-7 절) → docker compose up -d . 새 버전이 스키마를 바꿨다면 데이터베이스 복구 없이 이전 바이너리를 올려서는 안 됩니다.
-

6. 장애 대응

증상	확인할 곳	조치
컨테이너가 바로 종료. 로그에 <code>POSTGRES_DSN, BOOTSTRAP_ADMIN and BOOTSTRAP_ADMIN_PASSWORD are required</code> 또는 <code>BOOTSTRAP_ADMIN_PASSWORD must have at least 12 characters</code>	<code>docker compose logs seccheck</code>	<code>.env</code> 의 네 변수를 채웁니다. 비밀번호는 12자 이상
로그에 <code>ENCRYPTION_KEY must be 32 raw bytes or base64-encoded 32 bytes</code>	같은 곳	키 길이 확인. <code>openssl rand -base64 32</code> 로 만든 값이면 됩니다
로그에 <code>ENCRYPTION_KEY does not match this database</code>	같은 곳	다른 설치의 키로 올린 것입니다. 이 데이터베이스와 함께 백업한 원래 키로 다시 시작합니다. 그대로 올리면 증거가 전부 열리지 않습니다
로그에 <code>connect database:</code>	같은 곳	DSN 의 호스트·계정· <code>sslmode</code> 확인. PostgreSQL 이 먼저 떠 있어야 합니다
<code>/ready</code> 가 503	<code>docker compose logs</code> , PostgreSQL 상태	연결 풀 고갈이면 <code>seccheck_db_connections</code> 의 <code>acquired</code> 가 <code>total</code> 에 붙어 있습니다. DSN 에 <code>pool_max_conns</code> 를 올리거나 오래 걸리는 내보내기를 줄입니다
사용자 화면에 500, 서버 로그 <code>component=api</code> 에 <code>fields.error</code>	서버 로그 에서 요청 ID 로 검색	<code>fields.code</code> · <code>fields.error</code> 의 원인(대개 데이터베이스)에 따라 조치
증적이 검사 중 에서 안 움직임. 검사 대기 증적 이 줄지 않음	작업 큐 , 서비스 설정 > 파일 보안 의 연결 테스트 , 서버 로그 <code>scanner</code> 의 <code>evidence scan failed</code>	clamd 주소·기동 확인. 검사를 쓰지 않을 거면 ClamAV 악성코드 검사 를 끕니다. FAILED 작업은 재시도
알림 메일이 안 옴	작업 큐 의 <code>SEND_EMAIL</code> 마지막 오류, 서버 로그 <code>notification</code> 의 <code>email notification failed</code> / <code>digest delivery failed</code>	테스트 메일 보내기 로 SMTP 경로 확인. 수신자에게 이 메일이 없거나 이메일 알림 활성화 가 꺼져 있으면 재시도 없이 COMPLETED 로 끝냅니다

증상	확인할 곳	조치
감사로그 무결성 실패 알림, 서버 로그 audit 의 audit chain verification failed	감사로그 화면(알림의 링크가 멈춘 이벤트로 이동), 데이터베이스 직접 조작 이력	원인을 확인하고 백업과 대조한 뒤 전체 재검증. 데이터베이스를 직접 고친 적이 있는지부터 확인
증적 무결성 확인 실패 알림, seccheck_evidence_unreadable > 0	시스템 정보 > 증적 무결성 의 파 일명·심의번호·사유	볼륨 백업에서 해당 파일 복구. verify-evidence 로 전체 확인
서버 로그 maintenance 의 evidence volume is running out , seccheck_storage_writable == 0	시스템 정보 > 증적 저장소	볼륨 확장. 삭제 증적 보관 (일) 을 줄이면 파기가 빨라집니다
정기 점검 배지가 붉음 / seccheck_maintenance_last_run_seconds 증가	서버 로그 maintenance (could not record the sweep , audit chain verification failed to run 등)	대개 데이터베이스 문제. 해결 뒤 다음 시간에 자동 재개
작업 재시도 소진 알림, 서버 로그 maintenance 의 jobs exhausted their retries / job queue is not draining	작업 큐	마지막 오류를 읽고 원인 (SMTP·clamd) 제거 후 재시도
컨테이너 로그에 audit event could not be recorded , 서버 로그 audit 의 감사 이벤트를 기록하지 못했습니다. (데이터베이스가 그 줄은 받아 줄 때만 남습니다), seccheck_audit_write_failures > 0	데이터베이스 상태	기록 없이 수행된 행위가 있다는 뜻입니다. 즉시 조사
감사로그의 접속 IP 가 전부 같은 값	서비스 설정 > 접근 보안 > 신뢰 Reverse Proxy	Proxy IP/CIDR 을 등록합니다. 그 전까지는 요청 제한도 조직 전체로 묶입니다
SSO 로그인에 실패하고 화면에 코드가 보임	감사로그 LOGIN_FAIL (target_type=0IDC), 서버 로그 oidc	Discovery 연결 테스트 , Callback URL 과 Keycloak Redirect URI 일치 여부. 역할이 안 붙으면 directory groups received 로 그룹이 오는지 확인
관리자 계정이 잠기거나 비활성화됨	사용자 · 역할 의 잠금 해제 , 비활성 필터	다른 관리자가 풀거나 admin-recover --username <id> --unlock (잠금 해제와 재활성화를 함께 합니다). 장기 미접속으로 비활성화된 것이면 inactive_admin_lock_days 를 검토

7. 보안

설치 후 바로 바꿀 것

- `BOOTSTRAP_ADMIN_PASSWORD` 로 정한 비밀번호를 첫 로그인에서 바꾸고, SSO 관리자가 확인되면 부트스트랩 계정을 비활성화합니다.
- TLS 뒤에 두면 HTTPS 전용 `Secure Cookie` 를 겁니다.
- Reverse Proxy 뒤에 두면 신뢰 Reverse Proxy 를 채웁니다.
- 관리자·검토자·승인자에게 일회용 코드(TOTP) 필수 를 켜는 것을 권장합니다.
- 신뢰 경계 밖에서 접근 가능한 배치라면 `/metrics`를 인증 없이 공개 를 끄고 읽기 범위 API 키로 수집합니다.

외부에 열면 안 되는 것

- 컨테이너 8080 은 Reverse Proxy 에만 노출합니다. `/metrics` 는 사용자 수·로그인 실패 수·잠긴 계정 수·증적 용량을 드러냅니다.
- PostgreSQL 포트, SecCheck 외의 접근은 백업 계정으로만.
- `.env` 와 `ENCRYPTION_KEY` , 저장소·이미지·로그에 넣지 않습니다.

기본으로 켜져 있는 것

- 비밀번호 12자 이상, 흔한 값·아이디·서비스 이름 거절(`WEAK_PASSWORD`). 문자 종류 조합은 요구하지 않습니다 — 길이가 공격 비용을 올립니다.
- 로그인 실패 5회 잠금 15분, IP 별 로그인 실패 분당 30회, 전체 요청 분당 120회.
- 본인 심의 처리 금지(`allow_self_review=false`): 신청자는 자기 심의를 검토·승인할 수 없고, 검토한 사람은 승인할 수 없습니다.
- 증적 확장자·내용 교차 검증, AES-256-GCM 암호화 저장, 버전 보존.
- 감사로그 SHA-256 해시 체인과 매시간 자동 검증. 권한 없는 접근 시도는 `ACCESS_DENIED` 로 기록.
- 컨테이너는 `biroot(uid 10001)`, 읽기 전용 루트, `cap_drop: ALL` , `no-new-privileges` .

인증 연동

SSO 는 3-3 절의 OIDC 만 지원합니다. 로컬 계정과 SSO 계정이 함께 있을 수 있으며, SSO 계정의 비밀번호와 2단계 인증은 IdP 가 관리합니다. 그룹 매핑을 쓰면 퇴사자 권한이 다음 로그인에 회수되지만 `SYSTEM_ADMIN` 은 항상 이 제품 안에서 명시적으로 부여합니다.